

Lab Cyber : les livrables visibles, et une trajectoire 2030

Kélian Kaddouri

Pour Hugo Rapior • 2 septembre 2026

Ce que ce document est, et ce qu'il n'est pas. Tu connais le Lab mieux que moi, tu cosignes les deux rapports LUCY et tu animes l'atelier de novembre. Ce relevé ne te dit donc pas ce que fait le Lab : il te dit **ce qu'un tiers en voit** quand il ne dispose que des sources publiques, ce qui est une information différente. Je l'ai fait pour savoir où mon mémoire se branche, et il en est sorti un constat qui me semble valoir le détour. Tout ce qui n'est pas corroboré par une source publique est signalé comme tel.

1. Les cinq axes annoncés, et les livrables qui les portent

La page du pôle R&D énumère cinq axes pour le Lab Cyber. Confrontés aux publications réellement en ligne, trois sont portés par un livrable, trois ne le sont pas.

Axe annoncé	Livrable public qui le porte	État
Modélisation actuarielle du risque cyber	Atelier « Scénarios stochastiques, données textuelles et IA pour une meilleure quantification du risque cyber », journée 100 % Actuaire, 24 novembre 2025	porté
Marché de la cyberassurance, hors liste des cinq axes mais c'est le livrable cyber le plus visible	Rapports LUCY 2025 et LUCY 2026, analyse du marché français	porté
Audit de confidentialité des modèles d'IA	Livre blanc « Fondations et gouvernance pour une IA de confiance » avec Finance Innovation, et l'article du 10 juillet 2025 sur le GPAI Code of Practice	porté
Conformité DORA et NIS2 : cartographie ICT, KPI et KRI	Aucune publication dédiée trouvée. DORA n'apparaît que mentionnée, dans LUCY, comme réglementation applicable aux petites structures	non porté
Qualification et scoring des tiers ICT critiques	Aucune publication trouvée	non porté
Calcul du SCR cyber (assurance) et RWA cyber (banque)	Aucune publication. LUCY 2025 ne mentionne pas le SCR une seule fois, et l'atelier de novembre ne mentionne ni DORA ni SCR	non porté

Le constat, en une phrase. Le Lab annonce le calcul du SCR cyber et du RWA cyber, et c'est le seul de ses axes qui ne soit porté par aucune publication. C'est aussi, à la virgule près, le sujet de mon mémoire.

Le détail des trois livrables, puisque c'est ce qui fait foi

- **Les rapports LUCY.** Signés Hugo Rapior et Franck Osée Dountio Zaboue, assis sur 14 124 polices et 448 sinistres déclarés auprès d'Aon, Marsh et WTW. Ce qu'ils établissent : un ratio de sinistralité de 17 % en 2024 contre 12 % en 2023, un nombre de sinistres en baisse de 27 % mais des montants indemnisés en hausse de 43 %, le retour des sinistres XXL avec 21 M€ sur les incidents majeurs, des tarifs en baisse de 19,8 % sur les grandes entreprises et de 8,7 % sur les ETI, des capacités en hausse de 23 %, et des franchises en baisse de 15 % pour les grands comptes contre une hausse de 231 % pour les PME. C'est un livrable de **marché**.
- **L'atelier du 24 novembre 2025.** Avec Franck Dountio, Chadi Hanna pour Dattak et Caroline Hillairet. Trois méthodes annoncées : générateurs de scénarios stochastiques face aux pandémies cyber, processus de Poisson **auto-excités** intégrant contagion et divulgation de vulnérabilités, et exploitation de données textuelles par NLP et grands modèles de langage jusqu'aux transformateurs pour la sévérité. C'est un livrable de **méthode**.
- **Le livre blanc IA de confiance,** avec Finance Innovation, porté par l'équipe FCC : qualité de la donnée, dispositifs de gouvernance et de contrôle, cas d'usage sur les trois lignes de défense, et un parangonnage des solutions d'IA déployées en banque et en assurance dont la fraude et la cybersécurité. Complété par l'article sur le GPAI Code of Practice, adossé à l'article 53 de l'IA Act.

2. Trois lignes que les sources publiques ne corroborent pas

Ce n'est pas un reproche, et il faut le dire d'emblée : une intervention orale, une veille ou une contribution informelle ne laissent pas de trace publique. C'est une information sur la **visibilité externe** du Lab, et elle est utile parce qu'un interlocuteur qui vérifie trouvera exactement ce que j'ai trouvé.

- **PANAME.** Projet public piloté par l'ANSSI, la CNIL, le PEReN et Inria. Le Lab a bien l'axe « audit de confidentialité des modèles d'IA », mais aucune publication ne permet d'attribuer un livrable Nexialog sous ce label. La note interne le signale déjà, et je le confirme.
- **La présentation au European Congress of Actuaries.** Le congrès a lieu à Paris les 18 et 19 juin 2026 et son appel à intervenants comportait bien « Role of actuaries in modelling Cyber Risk » en risques émergents. Aucune intervention Nexialog n'apparaît dans les sources consultées.
- **Le risque géopolitique.** Il figure dans la présentation générale du cabinet parmi les risques transverses sur lesquels il innove, mais aucune publication dédiée n'est en ligne.

3. Où mon mémoire se branche, et le point qu'il faut que je te dise

La méthode publiée du Lab repose sur des processus de Poisson **auto-excités**, donc un Hawkes. Mon mémoire l'écarte au profit d'une cascade dirigée entre les cinq piliers. Présenté ainsi c'est un désaccord, et ce serait une mauvaise façon d'arriver.

Ce qui réconcilie les deux, et c'est un résultat plutôt qu'un arrangement. Une cascade *sans aucune* auto-excitation reproduit un ratio de branchement de 0,480 au pas journalier contre 0,551 mesuré, et retrouve même la demi-vie. Les deux familles sont donc **observationnellement équivalentes** à la résolution disponible : le rejet du Hawkes se reformule en équivalence suivie d'un choix de parcimonie interprétative. Ce résultat ne contredit pas la ligne du Lab, il la **borne**, et il coupe dans les deux sens puisqu'il interdit aussi de revendiquer qu'une des deux paramétrisations est la bonne *parce que* la donnée le dirait. Ce qui se défend est la traçabilité et la déclaration des limites, pas la supériorité du modèle.

La complémentarité est nette sur les objets. Le Lab publie le **marché** (LUCY) et la **méthode** (générateurs, NLP). Mon mémoire publie le **capital** : besoin en pilier 2 au titre de la non-conformité DORA, de 6 049 à 20 188 M€ selon l'état de conformité, soit un facteur 3,34, avec 1 980 nombres publiés dont chacun est rattaché au script qui le calcule. Trois briques différentes de la même offre, et la troisième est celle qui n'a pas encore de livrable.

4. La trajectoire 2026-2030, telle que le calendrier la contraint

Échéance	Ce que le jalon crée comme demande
30 avril 2026	Registre d'information, date de référence au 31 décembre 2025. À l'exercice à blanc de 2024, 6,5 % seulement des près de mille entités testées passaient les 116 contrôles qualité. C'est ce chiffre qui fabrique du mandat aujourd'hui, et c'est autant de la qualité de donnée que de la conformité.
2 août 2026	Obligations de l'IA Act sur les systèmes à haut risque. Les modèles de scoring, de détection de fraude et les agents conversationnels deviennent des actifs à cartographier et à auditer : l'axe gouvernance de l'IA cesse d'être une veille.
2026-2027	Premier cycle de supervision directe des 19 prestataires TIC critiques désignés le 18 novembre 2025, dont AWS, Azure, Google Cloud, Bloomberg, LSEG, IBM, TCS et Orange. C'est le jalon le plus exploitable du lot : une liste nominative de dix-neuf points de concentration transforme l'accumulation par cause commune en exercice mesurable sur des tiers identifiés, au lieu d'un facteur posé.
17 janvier 2027	DORA pleinement applicable aux petites entités. Élargissement de l'assiette vers des acteurs sans direction des risques constituée : le besoin bascule vers de l'outillage et du modèle standardisé plutôt que du sur-mesure.
17 janvier 2028	Rapport de réexamen de DORA par la Commission, avec proposition législative possible. C'est la seule fenêtre où une méthode publiée peut peser sur le cadre plutôt que le subir, et elle se prépare deux ans à l'avance.
2026-2030	Stratégie nationale de cybersécurité. Le directeur général de l'ANSSI a fixé 2030 comme horizon d'une possible guerre cyber de haute intensité, avec risque de saturation des capacités de défense. Une menace corrélée et massive est le régime où un modèle de cascade et d'accumulation cesse d'être un raffinement.

5. L'offre qui en découle, en quatre briques

- **Conformité outillée, aujourd'hui.** Registre d'information, cartographie ICT, KPI et KRI, scoring des tiers critiques. Le mandat existe et le taux de 6,5 % le prouve. Mais c'est la brique qui se **banalise le plus vite** : dès que l'exercice se répète, il passe à l'outil et le prix baisse. Elle finance le reste, elle ne fait pas l'identité du Lab.
- **Quantification du capital, 2026-2027.** SCR cyber, RWA cyber, besoin en pilier 2 au titre de la non-conformité. C'est l'axe annoncé et non publié, celui qui distingue un cabinet d'actuariat d'un cabinet de cybersécurité, et celui qu'aucun outil ne remplace parce qu'il exige un modèle défendable devant un régulateur.
- **Accumulation et transfert, 2027-2028.** La suite naturelle de LUCY et des dix-neuf prestataires critiques : accumulation par cause commune, dépendance de queue, structuration de la cession. Le pont entre le livrable de marché déjà publié et le modèle de capital, et le premier levier qu'un client actionne avant le capital.
- **Audit de modèles, cyber et IA confondus, 2028-2030.** Les modèles d'IA deviennent des actifs TIC au sens du pilier 1 et l'ANSSI construit des schémas de certification. La compétence qui se vend alors n'est ni le cyber ni l'IA, c'est la **validation de seconde ligne** appliquée aux deux, avec la traçabilité comme livrable.

Le fil qui relie les quatre. De 2026 à 2030, la demande passe de la **documentation** à la **preuve** : registres vérifiés, tests pilotés par la menace, audits de modèles effectifs. Savoir produire une chaîne de calcul dont chaque nombre se rattache au script qui le produit, c'est vendre exactement cela.

6. Le risque qui peut faire échouer la brique 2, et il porte sur mon propre travail

Toute la quantification repose sur une demande qui n'est pas *exigée* : il n'existe aucun module DORA en formule standard, donc le besoin de capital cyber reste un exercice d'ORSA, c'est à dire un récit que l'entité choisit de produire. Si le réexamen de janvier 2028 ne crée pas d'exigence chiffrée, la quantification restera une prestation de conviction et non de conformité, avec un marché plus petit et des cycles de vente plus longs. C'est la limite que mon mémoire publie lui-même, et c'est aussi la raison pour laquelle le jalon de 2028 mérite d'être préparé plutôt qu'attendu.

Deux réserves secondaires, du même ordre. La **donnée** reste le facteur limitant : rien dans le calendrier ne crée de base publique codant l'ordre des défaillances entre domaines de contrôle, et le seul chemin identifié est la notification d'incident majeur sous DORA, qui est exactement la recommandation de reporting que mon mémoire formule. Et la **différenciation méthodologique** est difficile à défendre, pour la raison d'équivalence observationnelle donnée plus haut.

7. Trois observations sur l'équipe, sous forme de questions

Je les pose plutôt que je ne les affirme : tu vois le carnet de commandes et le plan de charge que ce relevé ne voit pas.

- Ce que les traces publiques laissent voir du Lab est **mince** : un responsable de programme, des stagiaires ENSAE de fin d'études, et un recrutement en cours de consultant leader R&D cyber. Est-ce que la brique 2 attend ce recrutement, ou est-ce qu'elle peut démarrer avant ?
- Le canal de recrutement visible est **unique**, l'ENSAE et le master SFA. C'est efficace, et c'est fragile.
- Le pôle mène des **thèses CIFRE** avec Dauphine et le LEO sur la finance durable et le climat, et **aucune sur le cyber** alors que c'est l'un des trois labs. Une CIFRE cyber achèterait trois ans de recherche financée et un titre publiable, ce qu'aucune mission ne produit. Est-ce que le sujet a déjà été instruit ?

8. Ce que je propose

- **Publier la brique 2.** J'ai la chaîne de calcul, sa traçabilité et ses limites déclarées. La question n'est pas de savoir si je peux contribuer au Lab, c'est de savoir sous quelle forme on publie : note méthodologique interne réutilisable en avant-vente, article, ou les deux. La seconde forme est celle qui achète la légitimité externe qui manque à cet axe.
- **Prendre les dix-neuf prestataires critiques comme prolongement.** C'est le prolongement le plus direct de mon pilier 4, et il tombe dans la fenêtre de supervision 2026-2027.
- **Préparer le réexamen de 2028** avec l'Institut des Actuaire, ce qui ne se fait pas seul et se prépare tôt.

Relevé du 2 septembre 2026 sur sources publiques : pages Nexialog (pôle R&D, publications, LUCY 2025 et 2026, atelier 100 % Actuaire, livre blanc IA de confiance, GPAI Code of Practice), ESA, cyber.gouv.fr, EUR-Lex, Actuarial Association of Europe. Les chiffres du mémoire sont ceux du dépôt au 2 septembre 2026. Les ordres de grandeur d'équipe et l'ordonnancement des briques sont une hypothèse de lecture, pas un plan.